

Security+ 2.4 · Wireless Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —
Wireless Attacks (7:55) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Wi-Fi attacks include deauthentication/deassociation (forging frames to disconnect clients so they reconnect to an evil twin), evil twin (a rogue AP broadcasting the same SSID), RF jamming (disrupting the entire radio spectrum), and Bluetooth attacks such as bluesnarfing/bluejacking. Defenses: WPA3/SAE, rogue AP detection, RF monitoring; hiding the SSID does NOT help.

High-Yield Core Concepts Tested on Exam

- Evil twin: rogue AP with the SAME SSID — captures the handshake
- Deauth: disconnects clients so they fall onto the evil twin
- WPA3/SAE protects the handshake against password capture
- RF jamming disrupts the entire wireless spectrum
- Bluesnarfing/bluejacking target Bluetooth connections

Exam Tips & Classic Scenarios

- 'fake access point mimics legitimate one' = evil twin
- 'disconnects wireless clients' = deauthentication attack
- Hiding the SSID is NOT a valid defense

Typical Exam Scenario: Scenario: 'a user at a coffee shop connects to an open Wi-Fi that looks like the venue's, but it belongs to the attacker' = evil twin.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Wireless Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Credential cloning
- D)** Dumpster diving

2. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Evil twin: fake AP with the SAME SSID — captures the handshake'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Evil twin: fake AP with the SAME SSID — captures the handshake...

3. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Deauth: disconnects clients so they fall for the evil twin.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Deauth: disconnects clients so they fall for the evil twin.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'WPA3/SAE protects the handshake against password capture'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: WPA3/SAE protects the handshake against password capture...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'fake access point mimics legitimate one' = evil twin'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'fake access point mimics legitimate one' = evil twin...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'disconnects wireless clients' = deauthentication attack'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'disconnects wireless clients' = deauthentication attack...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: a coffee shop user connects to an open Wi-Fi that looks like the venue's, but belongs to the attacker' = evil twin. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: a coffee shop user connects to an open Wi-Fi that looks like the venue's, but ...
- B)** Temporarily disable audit logs to speed up system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Evil twin: fake AP with the SAME SSID — captures the handshake.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Evil twin: fake AP with the SAME SSID — captures the handshake...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Wireless Attacks): During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Deauth: disconnects clients so they fall into the evil twin'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal adherence terms
- C)** Implement the corresponding solution: Deauth: disconnects clients so they fall into the evil twin...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Wireless Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'WPA3/SAE protects the handshake against password capture'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: WPA3/SAE protects the handshake against password capture...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

2) D — Implement the corresponding solution: Evil twin: fake AP with the SAME SSID — captures the handshake....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): Evil twin: fake AP with the SAME SSID — captures the handshake.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) A — Implement the corresponding solution: Deauth: disconnects clients so they fall for the evil twin..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): Deauth: disconnects clients so they fall for the evil twin. A deauthentication (deauth) attack sends forged 802.11 management frames to disconnect clients from a legitimate access point. Attackers then lure victims to connect to an evil twin (rogue AP) to intercept traffic. Mitigations include 802.11w (Management Frame Protection) and WPA3.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: WPA3/SAE protects the handshake against password capture....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): WPA3/SAE protects the handshake against password capture. WPA3 uses Simultaneous Authentication of Equals (SAE) to provide forward secrecy and protect against offline dictionary attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'fake access point mimics legitimate one' = evil twin....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): 'fake access point mimics legitimate one' = evil twin.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

6) A — Implement the corresponding solution: 'disconnects wireless clients' = deauthentication attack....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): 'disconnects wireless clients' = deauthentication attack. A deauthentication attack sends forged frames to disconnect clients from a wireless network, often as a precursor to further attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Scenario: a coffee shop user connects to an open Wi-Fi that looks like the venue's, but

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): Scenario: a coffee shop user connects to an open Wi-Fi that looks like the venue's, but belongs to the attacker = evil twin. An evil twin is a rogue access point that impersonates a legitimate Wi-Fi network to lure users into connecting, enabling on-path (man-in-the-middle) attacks, credential theft, and malware delivery. The appropriate control is to implement the corresponding solution, which includes user awareness training, using VPNs on untrusted networks, enforcing WPA3/802.1X with certificate validation, and deploying wireless intrusion prevention systems (WIPS) to detect and block rogue APs.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Evil twin: fake AP with the SAME SSID — captures the handshake....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): Evil twin: fake AP with the SAME SSID — captures the handshake. An evil twin attack involves setting up a rogue access point that mimics a legitimate one to trick users into connecting, allowing the attacker to capture credentials or handshake data. The correct answer directly reflects this concept by recommending the implementation of the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Deauth: disconnects clients so they fall into the evil twin....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): Deauth: disconnects clients so they fall into the evil twin.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal adherence terms:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) B — Implement the corresponding solution: WPA3/SAE protects the handshake against password capture....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Wireless Attacks): WPA3/SAE protects the handshake against password capture. WPA3 uses Simultaneous Authentication of Equals (SAE), which replaces the WPA2 four-way handshake with a more secure Dragonfly handshake that is resistant to offline dictionary attacks and prevents password capture via eavesdropping.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.